

"Our university is launching a new, all-in-one online portal. This portal will handle everything from student registration and grade management to faculty collaboration and research data storage. The system must protect student privacy, ensure academic integrity, and manage potential conflicts of interest among researchers."

1. Define the security policy for this portal

Answer:

1. Student สามารถอ่าน transcript ของตัวเองได้เท่านั้น
2. student สามารถอ่านและแก้ไขรายการการลงทะเบียนเรียนของตัวเองได้ เมื่อถึงช่วงเวลาลงทะเบียนเรียนเท่านั้น
3. Professor สามารถอ่านและแก้ไข เอกสาร เกรดของรายวิชาที่ Professor ท่านนั้นสอน เมื่อถึงช่วงเวลาออกเกรด เท่านั้น
4. Professor สามารถอ่านการ record ลงทะเบียนเรียนรายวิชาได้ เมื่อถึงช่วงเวลาลงทะเบียนเรียนและ Record นั้นต้องเป็นของนักเรียนที่ลงทะเบียนในรายวิชาที่ Professor สอน
5. Researcher มีสิทธิ์ในการอ่านและแก้ไข Project งานวิจัยที่ตนเองกำลังทำอยู่ได้
6. Admin มีสิทธิ์ในการแก้ไขและอ่าน Student Transcript ได้
7. Admin มีสิทธิ์ในการแก้ไขและอ่าน Grade sheet ของแต่ละวิชาได้
8. Admin มีสิทธิ์ในการแก้ไขและอ่าน Record การลงทะเบียนเรียนได้
9. หากนักวิจัยเข้าถึง Project A ไปแล้วจะไม่มีสิทธิ์เข้าถึง Project B ที่มีผลประโยชน์ขัดกัน
10. ทุกการแก้ไข และ read ต้องมีการ audit log ทุกครั้ง

2. Object, subjects

answer:

Subjects: student, professor, admin, researcher, register officer

Objects: data registration record, student transcript, course grade, research data

3. Choose a primary Access Control Model or Security Framework

Define security policies

Step:

1. Define security model: เลือกใช้ bell-lapadula กับ user ที่ Authorize เพื่อป้องกันข้อมูลของ student เช่น transcript รั่วไหลออกไป, และ ใช้ biba กับ user ที่ Unauthorize เพื่อป้องกันไม่ให้ user ที่ไม่ได้สิทธิ์เข้าถึงข้อมูลเช่น student แก้ไขเกรดตัวเอง และก็ใช้ China- walls model ในการแก้ปัญหา conflict ระหว่าง researcher โดยการถ้า researcher เข้าถึง project A ทำให้ researcher คนนั้นห้ามเข้าถึง ข้อมูล project B ที่บริษัทที่เป็นคู่แข่งกับ project A ทำอยู่
2. Define Access control model: เลือกใช้ ABAC เพราะ สามารถกำหนดสิทธิ์ได้ว่า role ไหนทำอะไรได้บ้างโดยที่สามารถกำหนดช่วงเวลาได้เช่น professor ช่วงเวลานี้มีสิทธิ์แก้ไขเกรดเท่านั้น
3. Access control matrix: อยู่ที่ข้อสุดท้าย
4. กำหนด type enforcement: ACL เพราะ เราสามารถกำหนดได้เลยว่า asset ไหนใครเข้าถึงได้บ้าง ผ่าน role อีกทั้งยังถูกถามบ่อยในแง่ว่าไฟล์เกรดนี้ใครเข้าถึงได้บ้าง ซึ่ง ACL จะเหมาะสมกว่าในกรณีนี้

จะได้ว่า

answer: ABAC เพราะเราสามารถกำหนด role ได้ว่า role ไหนทำอะไรกับ asset ไหนได้บ้างโดยที่เพิ่มเติม environment field เพิ่มเข้ามาเพื่อแก้ปัญหาดังต่อไปนี้ เช่น student สามารถดูเกรดได้ก็ต่อเมื่อถึงเวลาที่กำหนดแล้วถึงสามารถดูได้ หรือ ปัญหา conflict ระหว่าง researcher ที่ถ้ามีประวัติเข้าถึง project A แล้วจะเข้าถึง project B ไม่ได้เป็นต้น

4. Access control matrix:

answer:

Role/Object	Student Transcript (Own)	Student Transcript (Other)	Course grade Sheet (Assigned)	Course grade Sheet (Others)	Data registration Record (Own)	Data Registration Record (Others)	Project A	Project B
Student	Read				Read / write			
Professor			Read / write		Read	Read		
Admin	Read/write	Read/write	Read/write	Read/write	Read/write	Read/write		
Researcher A							Read/write	
Researcher B								Read/write
Register Officer	Read/write	Read/write	Read	read	Read/write	Read/write		